

글로벌 AI 보안 동향 조사·분석 보고서



목차 Contents

- ▶ CSA, 에이전틱 AI 침해 대응을 위한 CISO 긴급 지침 제시
CSA, '26.7.28.
- ▶ NVIDIA 등, 개방형 AI 방어 생태계 'Open Secure AI Alliance' 출범
NVIDIA, '26.7.27.
- ▶ Cisco, 프런티어 AI 시대 Zero Trust의 전 계층 확장 필요성 제시
Cisco, '26.7.31.
- ▶ EU 집행위, 사이버복원력법(CRA) 이행 가이드스 발표
European Commission, '26.7.27.



CSA, 에이전틱 AI 침해 대응을 위한 CISO 긴급 지침 제시

개요

- ◆ Cloud Security Alliance(CSA)는 허깅페이스 운영 시스템 침해 사례의 초기 사후 분석을 토대로, 에이전틱 AI 환경에서 CISO가 즉시 실행할 대응 조치를 제시
 - ※ Cloud Security Alliance CISO Community Releases Emergency Guidance After Autonomous AI Model Breached Hugging Face's Production Systems During a Security Evaluation (CSA, '26.7.28.)
 - CSA에 따르면 벤치마크 평가 중이던 두 AI 모델이 제로데이로 샌드박스를 벗어나 허깅페이스 운영 시스템에서 원격 코드 실행·자격증명 탈취·내부 확산을 수행
 - CSA는 오용 방지 장치가 대응자 포렌식까지 제약하는 '가드레일 비대칭'을 지적
 - 50여 명의 CISO·보안 리더 의견을 반영한 브리핑에서는 에이전트가 외부 통제의 빈틈을 탐색하므로 행동·의사결정을 직접 관찰·제어해야 한다고 평가
- ◆ 사고대응 체계는 분석 가능한 대체 모델과 검증된 복구 절차를 사전 확보하고, 기술통제·훈련·신원 관리를 연계하는 방향으로 전환해야 한다고 권고
 - AI 재구성 과정의 환각 아티팩트를 사전 필터링하고, 불확실한 공격 경로 추정보다 알려진 정상 이미지에서 재구축하는 복구를 우선 적용
 - 지침의 범위는 고위험 에이전트·외부통신·긴급종료·자격증명·텔레메트리 통제에서 탐지·복구·훈련·비인간 신원 관리까지 단계적으로 확대

주요내용

- ◆ (침해사례에서 도출한 방어 전환) CSA는 이번 사고를 단일 취약점 문제라기보다 자율적으로 목표를 추구하는 에이전트가 기존 방어체계의 미확인 경로를 연쇄적으로 활용한 사례로 해석
 - CISO는 '에이전트가 경로를 찾아낸다'는 것을 전제를 반영하고, 샌드박스·외부 텔레메트리를 단독 방어선이 아닌 필수 통제로 활용
 - 고위험 에이전트에는 경계 통제와 에이전트 내부 통제를 함께 적용해야 한다고 강조
 - 자율 에이전트 활동은 개별 경보가 아니라 에이전트·신원·시스템 간 연속 행위를 연결해 탐지하고, 장기 실행 중 토큰 소비·자격증명 사용·횡적 이동과 같은 행동 변화를 관찰

- 복구는 AI의 추정 경로를 그대로 신뢰하지 않고, 검증 가능한 정상 상태를 기준으로 설계하고 반복 검증

CSA CISO 긴급 지침의 단계별 대응 조치		
시점	핵심 조치	세부 실행 내용
이번 주	에이전틱 AI 대응팀 구성	조직 차원의 대응팀에 경영진 책임자를 지정
	고위험 에이전트 우선 통제	코드 실행·자격증명·지속 메모리·인터넷 접근을 목록화하고 기본 차단형 외부통신·독립 긴급종료 적용
	자격증명·텔레메트리 정비	상시 자격증명 노출을 줄이고 에이전트 행위 텔레메트리가 전체 수집되는지 확인
이번 달	상관 탐지 체계 구축	에이전트·신원·시스템 활동을 연결해 개별 경보가 아닌 연속 행동 단위로 분석
	포렌식 모델·복구 검증	악성 코드 분석이 가능한 모델과 오픈웨이트 대체 모델을 시험하고 정상 이미지 기반 신속 복구를 검증
이번 분기	에이전틱 AI 모의훈련	자율 공격·제3자 공격·모델 분석 거부·동시다발 사고·급격한 토큰 소모·악성 에이전트 지속 활동을 시나리오화
	임시 보안표준·신원관리	비인간 신원·지출 한도·증거 보존을 규정하고 에이전트 신원을 접근관리·신원관리·변경관리에 명시적으로 편입

- ◆ (이번 주·이번 달의 우선 과제) 초기 단계는 에이전트의 존재와 권한을 파악하고, 사고 확산을 즉시 차단할 수 있는 통제와 가시성을 확보하는 데 집중
 - 조직 차원의 에이전틱 AI 대응팀을 구성하고 경영진 책임자를 지정
 - 코드 실행·자격증명·메모리·인터넷 접근 권한을 가진 에이전트를 우선순위로 관리하고, 가장 위험한 배포부터 외부통신을 기본 거부한 뒤 필요한 연결만 허용하는 방식으로 전환
 - 상시 자격증명을 줄이고 에이전트의 도구 사용과 시스템 접근을 재구성할 수 있을 정도로 텔레메트리가 수집되는지 확인해, 사고 후에 증거가 부족해지는 상황을 방지
 - 한 달 내에는 에이전트·신원·시스템 간 상관 탐지를 운영에 적용하고, 실제 사고에서 사용할 AI 분석 모델과 정상 이미지 복구 절차를 실전 조건으로 검증

- ◆ **(분기 단위 거버넌스와 회복력)** CSA는 기술통제를 일회성 조치로 끝내지 않고 에이전트 신원·비용·증거보존·제3자 위험까지 포함한 운영표준과 훈련으로 정착시킬 것을 요구
 - 모의훈련은 외부 공격자가 AI를 사용하는 상황뿐 아니라 내부 자율 에이전트가 제3자를 공격하거나, 포렌식 중 모델이 분석을 거부하거나, 여러 침해가 동시 발생하는 상황까지 포함
 - 에이전트의 대량 토큰 소비나 악성 상태의 장시간 지속을 사고 시나리오에 넣어 비용통제 관점의 대응 절차도 점검
 - 임시 에이전틱 보안표준에는 비인간 신원 관리, 지출 한도, 증거 보존을 포함하고, 에이전트와 서비스 계정을 기존 접근관리·신원관리·변경관리 체계의 예외가 아닌 명시적 대상으로 편입
 - 사고가 제3자 시스템으로 확산될 소지를 고려해 기술적 대응뿐 아니라 법적 책임과 보험 노출을 검토하게 한 점도 CISO가 에이전틱 AI 위험을 전사 위험관리로 다뤄야 함을 시사

시사점

- ◆ 에이전틱 AI 보안은 네트워크 경계와 샌드박스만 강화하는 방식에서 에이전트의 행동·의사결정·도구 사용을 직접 통제하는 방식까지 확대
 - 사고대응 계획에 '사이버 분석이 가능한 AI 모델'을 별도 대응자원으로 편입하고, 실제 포렌식 절차에서 작동하는지 정기 검증할 필요
 - 비인간 신원·자격증명·지출 한도·증거 보존을 IAM과 변경관리 정책에 통합해 에이전트의 권한 확대와 장기 실행을 사전에 제한하는 운영체계를 마련
 - 모의훈련 범위를 자율 에이전트의 제3자 공격·모델 분석 거부·동시다발 사고 등 AI 고유 사고양상까지 넓혀 기존 IR 절차에 반영

NVIDIA 등, 개방형 AI 방어 생태계 'Open Secure AI Alliance' 출범

개요

◆ NVIDIA와 클라우드·사이버보안·기업 소프트웨어·오픈소스·AI 연구 분야 주요 기업·기관이 개방형 모델·에이전트 하니스·보안 도구를 공동 개발·공유할 'Open Secure AI Alliance' 출범

※ Industry Leaders Unite in Open Secure AI Alliance for AI Safety and Security (NVIDIA, '26.7.27.)

- NVIDIA는 AI 보안도 소수 폐쇄형 시스템에 의존하기보다 개방형 모델·하니스는 방어자가 시스템을 직접 조사·수정·실행하게 하고 공개 모델·도구를 활용한 공동 방어 기반이 필요하다고 주장
- 허깅페이스는 폐쇄형 도구가 분석을 거부하자 자체 인프라에서 오픈웨이트 모델을 실행해 1만 7천 건 이상의 행위를 분석

◆ Alliance는 개별 모델이 아닌 에이전트 스택 전반을 공동 방어 대상으로 계층별 보안 기능 결합

- AI 에이전트의 안전성과 보안은 모델 가중치 공개 여부만으로 결정되지 않고 신원·권한·하니스·가드레일·로그·평가 등 전체 에이전트 스택의 통제 수준에 좌우된다고 강조
- NVIDIA는 에이전트 행동의 시험·추적·감사·거버넌스를 지원하는 NOOA*를 제공하고, 참여사는 신원·격리·안전한 모델 형식·스캐닝 등 개방형 방어 스택을 구축

* AI 에이전트를 별도 객체로 정의하고 관리할 수 있도록 설계된 오픈소스 연구 프레임워크로, 에이전트 성능을 향상시키는 기능을 기반으로 코드 리뷰, 단위 테스트 등 에이전트 행동 관련 기능 지원

Open Secure AI Alliance 참여 기업

분야	주요 참여 기업
빅테크·클라우드	NVIDIA, Microsoft, IBM, Dell Technologies, HPE, NetApp, Cloudflare, Crusoe, G42, Snowflake, Databricks, Cloudera, World Wide Technology
보안 기업	CrowdStrike, Palo Alto Networks, Fortinet, Palantir, Zscaler, F5, Upwind
반도체·하드웨어·통신	SK Telecom, Cadence, Synopsys, Nokia
오픈소스·SW 생태계	Linux Foundation, Hugging Face, GitHub, Red Hat, vLLM, LangChain, Elastic, Box, ServiceNow, Salesforce, SAP, Adobe, Siemens
AI 개발·연구	NAVER, SpaceXAI, Mistral, Perplexity, Cognition, Nous Research, Reflection AI, Thinking Machines Lab, Factory AI, OpenClaw, TrendAI,
소비자 서비스	Uber, DoorDash, Capital One

주요내용

- ◆ (개방형 방어 생태계 논리) Alliance는 공격자의 강력한 AI 접근을 차단하는 데만 주력하기보다 방어자도 검증·수정·통제 가능한 프런티어급 도구를 확보해야 한다는 문제의식에서 출발
 - NVIDIA는 개방형 모델의 악용 위험을 인정하면서도 가중치 폐쇄만으로 공격자의 AI 활용을 충분히 억제하기 어렵다고 설명
 - 따라서 개방성을 제한하기보다 강력한 안전장치, 악의적 오용 금지 규칙, 엄격한 평가, 신속한 취약점 보완을 결합해 방어자의 검증·개선 능력을 유지하는 방향을 제안
 - 폐쇄형·개방형 프런티어 모델을 보완재로 보고, 투명성·현장 적응·주권적 통제가 필요한 보안업무에는 개방형 수단을 확보해야 한다고 주장
 - 허깅페이스 사례는 자체 조사·수정·실행이 제한되면 사고대응이 지연될 수 있어 다중 공급자 확보와 단일 실패지점 회피가 필요함을 시사
 - Alliance는 Akrites·OpenSSF 작업을 토대로 취약점 보완·공개를 촉진하고, 에이전트 보안 기능을 공동 기반으로 축적

Open Secure AI Alliance가 제시한 개방형 AI 방어 스택의 주요 구성

방어 영역	공개 기술·기여	보안 기능
에이전트 하니스	NVIDIA NOOA	모델과 하니스의 결합을 개선해 에이전트 행동의 시험·추적·감사·거버넌스를 지원
신원	HPE SPIFFE/SPIRE	AI 에이전트·서비스를 암호학적으로 검증해 승인된 워크로드만 통신하고 자원에 접근하도록 허용
모델 형식	Hugging Face Safetensors	모델 가중치를 투명하게 저장하고 원격 코드 실행이 없는 안전한 형식 제공
오픈소스 공급망	IBM·Red Hat Lightwell	디지털 서명 패치로 오픈소스 공급망 전반에 보안을 확장
다중 모델 스캐닝	Microsoft MDASH	전문화된 AI 에이전트가 취약점을 탐색·토론하고 실제 악용 가능성을 입증
코딩 에이전트	SpaceXAI Grok Build	Grok Build를 공개해 신뢰·투명성을 높이고, Grok 계열 가중치 공개도 계획
공동 방어 인프라	데이터셋·평가 프레임워크·공격 시뮬레이터·레드팀 도구	공동 평가·공격 시뮬레이션·레드팀 수행 기반 제공

- ◆ **(에이전트 전체 스택 중심 보안)** NVIDIA는 AI 에이전트를 단순 언어모델이 아니라 모델·하니스·가드레일이 결합된 복합 시스템으로 보고, 전체 실행 스택을 검증 가능한 대상으로 전환
 - 모델 자체 안전성 평가와 별도로 에이전트가 어떤 신원으로 어떤 자원에 접근해 어떤 도구를 호출하는지 추적할 수 있어야 하며, 하니스와 로그가 이러한 운영통제의 핵심 기반
 - NOOA는 에이전트 행동의 시험·추적·감사·거버넌스를 지원하는 공개 연구 프레임워크로, 모델 가중치보다 실행 계층의 투명성을 확대
 - Alliance 참여사의 기여는 암호학적 워크로드 신원, 안전한 모델 저장 형식, 서명된 공급망 패치, 다중 모델 취약점 스캐닝 등 상이한 계층을 연결해 단일 모델 중심이 아닌 방어스택 구성
 - 공개 도구는 다수 방어자가 동일 기술을 조사·시험·수정할 수 있게 해 보안 결함의 조기 발견과 빠른 보안을 촉진하고, 특정 공급자에 종속되지 않는 자체 통제 여지를 확보하는 수단
- ◆ **(정책·산업 방향)** Alliance는 규제기관이 개방형 프런티어 AI를 일률적 위험 요인으로 취급하기보다 방어 자산으로 평가해야 한다고 촉구
 - 개방형 모델·하니스·보안 도구에 대한 포괄적 제한은 방어 역량을 약화하고 소수 폐쇄형 제공자에 권한·의존·취약성을 집중시킬 수 있다는 것이 NVIDIA의 정책적 문제 제기
 - 정부와 기업이 데이터셋·평가 프레임워크·공격 시뮬레이터·레드팀 도구 같은 공유형 AI 방어 인프라에 공동 투자해 개별 조직이 반복해 동일 기반을 구축하는 비용을 줄일 것을 제안
 - 폐쇄형과 개방형 모델을 병행하는 다중 모델 전략은 포렌식·로컬 데이터 처리 등 상황별 요구에 맞는 방어 수단의 선택 폭을 넓히는 구조

시사점

- ◆ AI 보안정책은 위험 평가 단위를 개별 모델에서 신원·권한·하니스·로그 등을 포함한 에이전트 스택으로 확장할 필요
 - 기업은 특정 모델의 분석 거부·서비스 접근 불가에 대비해 자체 실행 가능한 대체 수단을 검증하고 다중 공급자 체계를 확보할 필요
 - 에이전트 신원·안전한 모델 형식·공급망 서명·다중 모델 스캐닝 등 공개 기술을 상호 연계하면 단일 제품 도입보다 계층별 통제를 조합하는 방어 아키텍처 구축에 활용 가능
 - 정부·산업 차원에서는 공동 데이터셋·평가·공격 시뮬레이터·레드팀 도구의 개방형 기반을 확충하되 오용 방지·평가·취약점 보완 절차를 동시에 운영하는 거버넌스 필요

Cisco, 프런티어 AI 시대 Zero Trust의 전개층 확장 필요성 제시

개요

- ◆ Cisco는 프런티어 AI가 취약점 발견을 가속하고 자율형 IT 에이전트 활용이 확대되자, 최소권한을 전 계층으로 확장한 Zero Trust 원칙 적용을 제안

※ The Zero Trust Imperative for the Frontier AI Era (Cisco, '26.7.31.)

- 비보안 스크립트가 권한을 행사하는 자율 에이전트로 전환되면서 공격면과 비인간 신원이 확대
- Cisco는 최소권한을 AI 시대 핵심 원칙으로 제시하고, CSA·SANS·OWASP 공동 브리핑도 자산 인벤토리와 횡적 이동 방지 중심의 같은 접근을 뒷받침한다고 소개
- Zero Trust를 사용자 접속제어에 그치지 않고 애플리케이션, 에이전틱 AI, 네트워크·클라우드 인프라, 워크로드, 커널 프로세스·메모리·파일 접근까지 확장하는 아키텍처로 설명

- ◆ Cisco는 'Inventory(식별) → Enforce(적용) → Detect and Respond(탐지·대응)' 운영모델을 기반으로 AI-BoM과 계층별 통제를 연결

- 에이전트와 에이전트 신원을 별도 관리하고 AI-BoM에 에이전트·데이터 소스·LLM·MCP·도구를 포함해 구성요소별 권한을 파악하도록 제안
- 통제 계층은 구역 설정·매크로 세그멘테이션에서 신원·속성 기반 정책, 워크로드 마이크로 세그멘테이션, eBPF* 프로세스 제어, 에이전트 신원 제한, 프롬프트 가드레일까지 연결

* extended Berkeley Packet Filter(eBPF) : 운영체제의 핵심인 커널 코드를 직접 수정하지 않고 개발자가 가상 공간에서 안전하고 효율적으로 사용자 기능을 확장할 수 있도록 해주는 리눅스 기술

주요내용

- ◆ (3단계 Zero Trust 운영모델) Cisco는 AI 시대의 Zero Trust를 '무엇이 존재하고 정상인지 파악 → 필요한 접근만 허용 → 기준 이탈을 감지해 동적으로 대응'하는 폐쇄형 피드백 루프로 정의
- Inventory는 사용자·앱뿐 아니라 에이전트·AI 구성요소, 인프라 버전·네트워크/클라우드 설정·IaC까지 자산 범위를 확대
- 일반 앱은 목적·정상 행동·라이브러리·버전 BoM을, AI 앱은 에이전트·데이터 소스·LLM·MCP·도구를 포함한 별도 BoM을 구성

- Enforce 단계에서는 인프라 구역화·소프트웨어 정의 세그멘테이션, 신원·속성 기반 접근제어, 워크로드 마이크로 세그멘테이션으로 중요 자원 이동 경로를 최소화
- AI 계층에서는 에이전트 신원을 의도된 자원으로 제한하고, MCP·LLM 게이트웨이에 프롬프트 수준 가드레일을 적용해 네트워크·워크로드 제어와 모델 상호작용 통제를 연결
- Detect and Respond는 정상 기준선에서 벗어난 활동을 감지해 정책·접근을 동적으로 조정하고, Inventory·Enforce 단계와 피드백 구조를 형성

Cisco가 제시한 AI 시대 Zero Trust의 계층별 적용 대상과 통제 방식

통제 대상	관리·통제 초점	강제·대응 방식
사용자 신원	사용자·일상적 사용 형태·접근 애플리케이션 파악	신원·속성 기반 최소권한과 이상 위치·동시접속 시 단계적 인증
애플리케이션	목적·정상 행동·라이브러리·버전 BoM 관리	애플리케이션 의존관계 기반 마이크로 세그멘테이션과 취약 서비스 격리
에이전틱 AI	에이전트·에이전트 신원·데이터·LLM·MCP·도구를 AI BoM으로 관리	에이전트 신원을 의도된 자원으로 제한하고 행동 드리프트 시 종료·접근 차단
인프라	장비·소프트웨어 버전·네트워크/클라우드 설정·IaC 저장소 관리	구역 설정·매크로 세그멘테이션으로 횡적 이동을 제한하고 취약 자산 노출 축소
워크로드	애플리케이션 의도와 서비스 간 의존성 지도화	마이크로 세그멘테이션으로 필요한 통신만 허용하고 위험도 변화에 따라 정책 재분류
커널	프로세스·메모리·파일 접근	eBPF 기반 나노 세그멘테이션(nano-segmentation)으로 패치 전 악용 경로 차단
프롬프트·MCP	에이전트·MCP·LLM 게이트웨이 호출	게이트웨이 기반 적응형 가드레일로 선언되지 않은 의도와 위험한 호출 차단

- ◆ (패치 공백을 줄이는 동적 대응) Cisco는 패치까지 허용되는 시간이 8~9시간 수준으로 줄어 조직이 따라가기 어렵다고 보고, 패치 전 접근경로와 영향범위 축소를 강조
- 새로운 취약점이 공개되면 마이크로서비스를 고위험 범주로 묶어 패치 전 격리하고, 수정 후 정상 정책으로 자동 복귀하는 방식으로 취약점 상태와 네트워크 정책을 연동
 - 사용자 신원의 위치·동시접속 이상에는 추가 인증을 요구하고, 에이전트 행동이 의도에서 벗어나면 종료하거나 게이트웨이 접근을 차단

- eBPF 기반 프로세스·메모리·파일 통제는 취약점 발견과 패치 사이에 정밀 보호막을 제공해 실행 수준에서 악용 경로를 제한
 - 탐지·대응을 인벤토리와 정책결정·집행에 연결한 피드백 루프로 운영해 SOC의 전면 사고대응으로 확전되는 상황을 방지
 - 결국 패치 공백이 존재하는 동안에는 패치만으로 위험을 해소하기 어려워 접근권한·세그멘테이션·동적 격리를 결합한 Zero Trust가 운영상 필수요건이라는 결론
- ◆ **(AI를 활용한 Zero Trust 구현)** Cisco는 복잡한 세그멘테이션 프로젝트의 운영 부담을 AI가 줄일 수 있다며, 공통 정책결정지점과 여러 계층의 정책집행지점을 연결하는 아키텍처를 제시
- 공통 정책결정지점이 관리자 의도를 토폴로지 기반 규칙으로 변환해 스위치·방화벽·SSE·워크로드·클라우드 방화벽·eBPF 등에 일관되게 배포
 - AI를 자산·의도·의존관계를 분석해 Zero Trust 정책을 대규모로 생성·조정하는 수단으로 활용하되, 정확한 인벤토리와 최소권한 기준선이 전제
 - AI는 보안 코드 생성·품질 향상, 취약 인프라 탐색, 패치 운영에도 활용돼 Zero Trust 구현·운영의 자동화를 지원

시사점

- ◆ 기업의 AI 자산관리 범위를 모델 목록에 그치지 않고 에이전트·비인간 신원·데이터 소스·MCP·도구를 포함한 AI 애플리케이션 BoM으로 확장해 최소권한 정책의 기준선을 마련할 필요
- AI가 취약점 발견을 가속하는 만큼 패치 SLA 단축과 네트워크·워크로드·커널 세그멘테이션으로 패치 전 이동경로와 피해범위를 축소할 필요
 - 사용자·에이전트·애플리케이션·인프라를 각각 분리 관리하기보다 동일한 정상상태와 정책 기준을 공유하고, 행동 드리프트를 실시간 차단하는 탐지·대응 루프를 구축할 필요
 - AI 기반 정책 자동화는 지연된 세그멘테이션 사업의 실행력을 높일 수 있으나, 자동 생성 정책의 품질은 자산 인벤토리·의존관계·관리자 의도가 정확하다는 전제에 의존

EU 집행위, 사이버복원력법(CRA) 이행 가이드스 발표

개요

- ◆ EU 집행위원회는 제조사·개발자와 모든 규모 기업이 CRA 의무를 실제 제품·사업에 적용하도록 **적용범위·중대한 변경·지원기간·보고·위험평가 등을 명확화한 신규 이행 가이드스를 발표**

※ Commission publishes new guidance to support businesses' implementation of the Cyber Resilience Act (European Commission, '26.7.27.)

- 어떤 제품이 CRA 적용대상인지, 기존 제품의 변경이 언제 '중대한 변경'에 해당하는지, 지원기간을 어떻게 이해해야 하는지 등 **기업이 실무에서 판단하기 어려운 핵심 개념을 구체화**
- 보고 의무와 위험평가 요구사항을 실제로 충족하는 방법을 설명해 법 조문 수준의 의무를 제품 개발·운영 과정의 실행 항목으로 연결하도록 지원
- 기업 질의에 답하는 형식을 취해 특히 마이크로기업·중소기업의 대응 부담을 낮추는 데 중점
- ◆ 집행위는 사이버보안 역량을 갖춘 프런티어 AI 모델의 발전으로 CRA의 신속하고 정확한 이행 필요성이 더욱 커졌다고 설명
- CRA는 '24년 12월부터 발효 중이며, 보고 의무는 '26년 9월 11일부터 적용될 예정
- **전체 준수 기한은 '27년 12월로 제시됐으며, 이번 가이드스는 규제 준수의 예측가능성을 높이고 불필요한 부담과 법적 불확실성을 줄이기 위한 집행위의 규제 단순화 조치**

주요내용

- ◆ **(가이드스의 핵심 명확화 영역)** 집행위는 CRA의 새로운 의무를 일괄적으로 반복하기보다 기업이 실제 이행 과정에서 판단해야 할 적용대상과 변경·지원·보고·위험평가의 경계를 구체화
- 적용범위 안내는 기업이 자사 디지털 제품의 CRA 의무 대상 여부를 먼저 판정하는 출발점
- '중대한 변경'의 의미를 명확히 해 이미 시장에 제공된 제품이나 소프트웨어의 변경이 새로운 규제 의무와 어떤 관계를 갖는지 기업의 판단 불확실성을 줄이는 데 초점
- 지원기간에 관한 설명은 제품에 대한 사이버보안 지원을 어느 기간까지 고려해야 하는지 이해하도록 돕는 항목으로, 제품 전주기 관점의 의무 이행과 연결

- 보고 의무와 위험평가 요구사항은 단순한 정책 선언이 아니라 기업이 실제 절차로 이행해야 하는 핵심 영역에 해당
- 기업 질의와 사례를 통해 동일한 법적 요구사항이 기업 규모와 제품 상황에 따라 어떻게 적용되는지 제시

EU CRA 가이드언스의 주요 항목과 이행 준비 포인트

가이드언스 주요 항목	기업 관점의 준비 포인트
적용범위	제품·서비스 포트폴리오별 CRA 적용 여부를 우선 판정
중대한 변경	업데이트·변경 시 규제상 영향 판단 절차를 정립
지원기간	제품 전주기 지원 책임의 기간을 내부 계획에 반영
보고 의무	2026년 9월 11일 적용에 앞서 보고 책임·절차를 준비
위험평가	제품 보안 위험평가를 준수 절차에 연결
마이크로기업·중소기업	실무 예시·사용 사례를 활용해 필요한 대응 수준을 파악
이행 일정	발효(2024.12), 보고 적용(2026.9), 전체 준수(2027.12) 일정 관리

◆ (단기 우선순위는 적용 판정과 보고 준비) '26년 9월 11일 보고 의무 적용에 맞춰 전체 준수 기한과 별도로 단계별 준비가 필요

- 보고 의무 이행방법과 위험평가 요구사항을 함께 설명함으로써 보안사건이나 취약점 관련 정보를 어떤 내부 절차로 평가하고 규제 준수 활동으로 연결할지 사전 준비의 필요성을 제시
- 적용대상과 중대한 변경 여부를 판정해야 이후 보고·위험평가·지원 의무 범위를 정확히 설정할 수 있으므로 제품 목록과 변경관리 과정에서 CRA 적용 여부를 확인하는 절차가 중요

◆ (규제 단순화와 보안 요구의 병행) 집행위는 강한 사이버보안 의무를 유지하면서도 실무 예시와 기업 질의 답변을 통해 이행 과정의 불필요한 행정부담과 법적 불확실성을 줄이는 방향을 강조

- 명확한 해석과 예측가능한 이행지침을 통해 기업이 CRA 의무를 적시에 확신을 갖고 이행하도록 지원
- 기업 친화성과 사이버보안을 상충하는 목표로 보지 않고, 제품 보안을 높이면서 불필요한 규제비용을 줄이는 접근을 제시

시사점

- ◆ EU 시장과 연결된 디지털 제품 기업은 보고 의무 적용 시점에 맞춰 내부 보고 책임과 절차의 준비상태를 점검할 필요
 - 제품 개발·변경관리의 사전 검토 항목에 CRA 적용 여부와 '중대한 변경' 판단을 포함해 출시 후 뒤늦은 규제 검토를 줄일 필요
 - 위험평가와 지원기간 요구를 제품 전주기 보안관리와 연계하고, 신규 가이드선의 실무 예시를 활용해 법적 의무를 개발·운영 담당자가 실행 가능한 절차로 구체화할 필요
 - 마이크로기업·중소기업은 가이드선을 규제범위와 이행수준을 선별하는 기준으로 활용해 과도한 대응을 줄이고 필수 보고·위험평가 의무 누락을 방지할 필요